



APPLICATION & TECHNICAL REFERENCE

# Ply Legal Client Portal

---

*Features, architecture, APIs, data storage, configuration, and codebase guide*

**Product UI: Ply Legal | Client Portal**

Repository: [validifypro-visa-portal](#)

Code snapshot: 86740ed (2026-06-28)

Reviewed: 23 July 2026 • Current database mode: Firebase

## Contents

- 1. Executive overview
- 2. Users and product scope
- 3. Feature catalogue
- 4. Supported visa and intake flows
- 5. System architecture and data flow
- 6. Technology stack
- 7. External APIs and integrations
- 8. Internal API route catalogue
- 9. Where information is saved
- 10. Folder and code structure
- 11. Configuration and environment variables
- 12. Local development, build, and deployment
- 13. Testing and verification
- 14. Security and operational notes
- 15. Maintenance guide and appendices

**Documentation basis:** This guide was produced from the working repository and configuration files, not from the historical planning documents. Where a dependency or route exists but is not active, it is explicitly labelled as legacy, optional, or a stub.

## Document conventions

- “Firestore” means the default Cloud Firestore database in region asia-east2.
- “Matter” means a Zoho CRM Deal linked to a portal application through zohold.
- Paths such as applications/{appId}/data/questionnaire are Firestore document paths.
- “Route-level auth” describes checks implemented by the Next.js route handler itself.

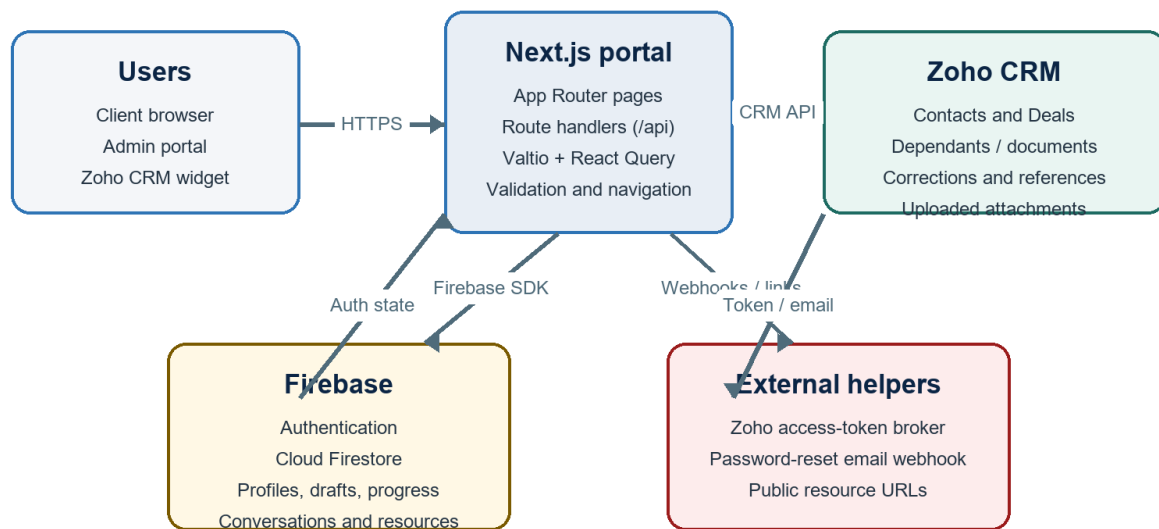
## 1. Executive overview

The Ply Legal Client Portal is a responsive immigration case-management portal. It lets clients sign in, maintain a profile, view visa matters sourced from Zoho CRM, complete long multi-step questionnaires, upload requested documents, review resources, submit corrections, and exchange case messages. Staff can view client conversations through a small admin surface or a Zoho CRM widget.

**Primary design:** Next.js provides the web interface and server routes. Firebase provides identity and the portal's working data. Zoho CRM remains the business system of record for contacts, matters, dependant records, requested documents, uploaded files, corrections, and CRM references.

| Area            | Current implementation                                                |
|-----------------|-----------------------------------------------------------------------|
| Frontend        | Next.js App Router with React; 131 page routes                        |
| Server API      | 34 Next.js route-handler files under app/api                          |
| Identity        | Firebase Authentication, email/password, persistent browser sessions  |
| Portal database | Cloud Firestore, default database in asia-east2                       |
| CRM             | Zoho CRM REST APIs; Australian data centre by default                 |
| Uploads         | Zoho Matter_Documents records and their Attachments                   |
| Questionnaires  | 110 intake pages across partner, protection, and temporary-work flows |
| Deployment      | Replit autoscale configuration; Next.js listens on port 5000          |

### Current application architecture



Files are uploaded to Zoho Matter\_Documents attachments; Firebase Storage is not used.

Figure 1. Current runtime architecture and data ownership.

## 2. Users and product scope

### 2.1 Client applicant

- Signs in only when the email exists in Zoho Contacts and Portal\_Access is Active.
- Completes profile, address, dependant, and visa-questionnaire information.
- Views all linked visa applications and their completion progress.
- Uploads evidence against Zoho Matter Document requests.
- Reads shared or visa-specific resources, submits document corrections, and exchanges messages.

### 2.2 Portal administrator or case staff

- Uses the admin conversation list and conversation detail pages when the Firestore user role is admin.
- Can reply from the portal or from the Zoho CRM widget through X-Admin-Key protected endpoints.
- Receives client message references and unread flags in the Zoho Client\_Messages module.

### 2.3 Zoho workflow integration

- Can provision or disable Firebase users through webhook-style endpoints.
- Pushes contact updates into Firestore and receives profile, dependant, questionnaire-status, document, correction, and message updates.
- Uses a separate access-token broker URL; OAuth refresh credentials are not stored in this codebase.

### 2.4 Public review recipient

A standalone route at `/review-pdf/{matterId}` renders questionnaire responses and supports browser print-to-PDF. It does not require a Firebase session; Firestore access therefore depends on the application's `publicReviewAccess` flag.

## 3. Feature catalogue

| Feature             | What it provides                                                                                                               |
|---------------------|--------------------------------------------------------------------------------------------------------------------------------|
| Access and sessions | Zoho eligibility gate, Firebase email/password login, browser-local persistence, sign-out, access-denied handling.             |
| Password lifecycle  | Forced first-login password change, forgot-password token generation, reset webhook, token hashing, Firebase token revocation. |

| Feature                 | What it provides                                                                                                               |
|-------------------------|--------------------------------------------------------------------------------------------------------------------------------|
| Profile management      | Personal details, address, contact data, dependants, validation, fetch from Zoho, and two-way Zoho sync.                       |
| Application dashboard   | Loads Firestore applications, refreshes linked Zoho Deals, maps visa types/statuses, removes duplicates/stale records.         |
| Questionnaire workspace | Progress dashboard, ordered intake navigation, save draft, continue, validation, page completion, and percentage tracking.     |
| Applicant modelling     | Main applicant, spouse/partner, children, migrating dependants, non-migrating family, sponsor, and per-profile form sections.  |
| Cross-application reuse | Imports matched applicant and shared questionnaire sections; includes a 482-to-186 import helper.                              |
| Dynamic definitions     | Code-based questionnaire definition with optional active Firestore override; currently used for the 482 character page.        |
| Document upload         | Reads Matter_Documents, validates type/size, creates or matches request records, uploads attachments, marks Awaiting Approval. |
| Resources               | Authenticated shared resources plus visa-template notes and external links grouped by category.                                |
| Document review         | Displays a document-review pane; creates and edits Zoho Corrections linked to the Matter.                                      |
| Messaging               | Firebase conversation history and unread flags; Zoho Client_Messages reference record; admin portal and CRM widget access.     |
| Review and PDF          | Searchable/collapsible questionnaire review with browser print output; separate matter-ID route.                               |
| Admin automation        | Create/re-enable users, revoke access, receive Zoho contact updates, and count questionnaires.                                 |

### 3.1 Current application navigation

The contextual application sidebar currently exposes Questionnaire, Upload Documents, Resources, and Document Review. Additional implemented pages exist for messages, tasks, review, and deliverables, but they are not listed in the current contextual sidebar.

**Deprecated message endpoints:** `/api/messages/create`, `/api/messages/fetch`, and `/api/messages/upload-attachment` return HTTP 410. The supported messaging endpoints are `/api/chat/messages` and `/api/chat/send`; message attachments are not implemented.

## 4. Supported visa and intake flows

| Public slug | Internal flow  | Pages                         | Scope                                                                     |
|-------------|----------------|-------------------------------|---------------------------------------------------------------------------|
| 186         | temporary-work | Shared 38-page implementation | Employer Nomination Scheme; rewrite injects <code>__subclass=186</code> . |

| Public slug      | Internal flow  | Pages                         | Scope                                                                                  |
|------------------|----------------|-------------------------------|----------------------------------------------------------------------------------------|
| 482              | temporary-work | Shared 38-page implementation | Skills in Demand; rewrite injects __subclass=482.                                      |
| 820 / partner    | partner        | 43 pages                      | Partner, spouse, children, sponsor, relationship, and all-applicant sections.          |
| 866 / protection | protection     | 29 pages                      | Protection applicant, spouse, children, employment, relationship, and shared sections. |

## 4.1 Temporary-work questionnaire

- Getting started and included-applicant selection.
- Main applicant: details, other names, identity, employment, education, language, skills, and contact details.
- Spouse/partner and child sections, including identity, education, language, custody, and other details.
- Migrating dependants and non-migrating family members.
- All applicants: addresses, countries of residence, contact details, visas, travel history, health, and character.
- Review/submit with strict completion checks and Zoho questionnaire-status update.

## 4.2 Partner questionnaire

- Main applicant, spouse/partner, children, and included dependants.
- Family sponsor: details, identity, family, circumstances, addresses, contacts, previous sponsorship, travel, and character.
- Relationship evidence: current relationship, relationship details, previous relationships, and supporting witnesses.
- All applicants: addresses, contacts, visas, travel, future travel/address, health, character, and personal contacts.

## 4.3 Protection questionnaire

- Main applicant, spouse/partner, children, current relationship, and employment-offer/business details.
- All applicants: addresses, contacts, visas, travel history, future travel, future addresses, health, character, and contacts.

- Review/submit uses the same shared draft and completion model as the other flows.

## 5. System architecture and data flow

### 5.1 Login and application synchronisation

1. The browser calls `/api/auth/verify-zoho` with the email address.
2. The server checks Zoho Contacts and requires `Portal_Access = Active`.
3. Firebase Authentication validates the email/password account.
4. The portal loads `users/{uid}` from Firestore and refreshes the contact's related Zoho Deals.
5. Deals are normalised into `applications/{appld}`; the Zoho Deal ID is stored as `zohold`.

### 5.2 Questionnaire save and submit

6. A page loads the application draft from `applications/{appld}/data/questionnaire`.
7. Forms use React Hook Form and page-specific validation; selected profile sections can auto-save after a 500 ms debounce.
8. Save operations persist first and update Valtio state after success.
9. Completion keys and the calculated percentage are stored in `applications/{appld}/data/completion`.
10. The linked Zoho Deal's `Questionnaires_Status` becomes In Progress or Submitted.

### 5.3 Documents and messages

- Document requirements are read from the Zoho Deal's `Matter_Documents` related list. Uploads are attached to the `Matter_Documents` record, not to Firebase.
- Messages are authoritative in Firestore `conversations/{conversationId}/messages`. Zoho receives a lightweight `Client_Messages` reference with preview, unread flags, timestamps, and portal link.
- Corrections are created and updated directly in the Zoho Corrections module and linked to the Matter.

## 6. Technology stack

| Layer      | Technology                                                     |
|------------|----------------------------------------------------------------|
| Framework  | Next.js 16.0.10, App Router, webpack builds, React Strict Mode |
| UI runtime | React 18.3.1 and React DOM 18.3.1                              |

| Layer                 | Technology                                                                            |
|-----------------------|---------------------------------------------------------------------------------------|
| Language              | Primarily JavaScript/JSX; TypeScript 5.6 compiler with allowJs=true and strict=false  |
| Styling               | Tailwind CSS 3.4, PostCSS, custom Ply Legal fonts, responsive utility classes         |
| Component primitives  | Radix UI, shadcn-style local components, Lucide icons, class-variance-authority       |
| Forms and validation  | React Hook Form, Zod, @hookform/resolvers                                             |
| Client state          | Valtio stores; TanStack React Query provider and fetch helper                         |
| Backend services      | Firebase JS SDK 12.4 and Firebase Admin SDK 13.5                                      |
| CRM integration       | Axios, form-data, and a custom ZohoCRMClient                                          |
| Identifiers and dates | nanoid and date-fns                                                                   |
| Testing               | Playwright 1.60 plus small Node-style unit tests                                      |
| Package and runtime   | pnpm lockfile; application targets Node.js 20+, Firebase Functions declare Node.js 22 |

## 6.1 Installed but not active in the primary runtime

- PostgreSQL/Neon/Drizzle: dependencies and drizzle.config.ts exist, but the Postgres adapter is a TODO stub and shared/schema.ts is absent.
- Firebase Functions: functions/index.js contains the starter template and exports no active business function.
- Express, Passport, WebSocket, Vite, and Wouter packages remain installed from an earlier architecture but are not the current Next.js application path.
- Firebase Storage is configured, but storage.rules denies every read and write.

## 7. External APIs and integrations

| Integration             | Endpoint/configuration                   | Use                                                                                                    |
|-------------------------|------------------------------------------|--------------------------------------------------------------------------------------------------------|
| Zoho CRM REST API v7    | https://www.zohoapis.{datacenter}/crm/v7 | Contacts, Deals, related lists, CRUD, search, and COQL. Default datacenter is com.au.                  |
| Zoho attachment API v8  | https://www.zohoapis.{datacenter}/crm/v8 | Uploads files to Matter_Documents/{id}/Attachments.                                                    |
| Zoho token broker       | ACCESSTOKEN_URL or ZOHO_ACCESS_TOKEN_URL | Returns an OAuth access token; cached in server memory for 50 minutes.                                 |
| Firebase Authentication | Firebase JS/Admin SDK                    | Email/password sign-in, account provisioning, password changes, disabling users, and token revocation. |
| Cloud Firestore         | Firebase JS/Admin SDK                    | Portal profiles, applications, questionnaire drafts, completion, messages, resources, and definitions. |

| Integration                  | Endpoint/configuration                      | Use                                                                                               |
|------------------------------|---------------------------------------------|---------------------------------------------------------------------------------------------------|
| Firestore REST API           | firestore.googleapis.com/v1                 | The Zoho Deal refresh route queries and writes application documents using the caller's ID token. |
| Password-reset email webhook | PORTAL_RESET_EMAIL_WEBHOOK_URL              | Receives email, resetLink, and contactId. If absent, the link is generated but not emailed.       |
| External resources           | Stored URLs, including Zoho WorkDrive links | The Resources page opens active external links; the portal does not copy those files.             |
| Brand asset CDN              | cdn.prod.website-files.com                  | Provides the favicon declared by the root layout.                                                 |

## 7.1 Zoho modules used

| Module             | Portal usage                                                                                          |
|--------------------|-------------------------------------------------------------------------------------------------------|
| Contacts           | Portal eligibility, profile fields, password flags/reset token, owner/account metadata.               |
| Deals              | Visa matters/applications, Stage, visa type, closing date, questionnaire status, documents_json.      |
| Partner_Dependents | Spouse, children, other dependants, and non-migrating family members.                                 |
| Matter_Documents   | Requested-document records, status, comments, serial order, and file attachments.                     |
| Corrections        | Field-level review issues linked to a Matter.                                                         |
| Client_Messages    | Conversation reference, latest preview/time, unread flags, Firebase conversation ID, and portal link. |

**Not used:** The codebase contains no payment, mapping, analytics, generative-AI, or SMS API integration.

## 8. Internal API route catalogue

All routes are implemented as Next.js App Router route handlers. “None” below means the handler does not verify a Firebase token, admin role, or shared key itself; the absence of a route-level check should not be treated as public authorisation.

### Authentication and administration

| Method | Route                      | Purpose                                                             | Auth                 |
|--------|----------------------------|---------------------------------------------------------------------|----------------------|
| POST   | /api/auth/verify-zoho      | Gate login by Zoho contact and Portal_Access.                       | None                 |
| POST   | /api/auth/forgot-password  | Create hashed reset token in Zoho and call email webhook.           | None                 |
| POST   | /api/auth/reset-password   | Validate token, update Firebase password/profile, clear Zoho flags. | None                 |
| POST   | /api/auth/password-changed | Clear temporary-password/reset flags in Zoho.                       | None                 |
| POST   | /api/admin/create-user     | Create or re-enable Firebase user and Firestore profile             | Bearer secret if set |

| Method | Route                             | Purpose                                               | Auth                 |
|--------|-----------------------------------|-------------------------------------------------------|----------------------|
|        |                                   | from Zoho.                                            |                      |
| POST   | /api/admin/revoke-access          | Disable Firebase user, revoke tokens, update profile. | Bearer secret if set |
| POST   | /api/webhooks/zoho-contact-update | Push Zoho contact/profile changes into Firestore.     | Bearer secret if set |

## Applications, profiles, and questionnaires

| Method        | Route                               | Purpose                                                        | Auth                           |
|---------------|-------------------------------------|----------------------------------------------------------------|--------------------------------|
| POST          | /api/applications/fetch-zoho-deals  | Fetch related Deals and reconcile Firestore applications.      | ID token in body for Firestore |
| GET/<br>PATCH | /api/deals/{dealId}                 | Read documents_json or update Questionnaires_Status.           | None                           |
| POST          | /api/profile/fetch-zoho             | Fetch Contact, dependants, and Deals; optionally save profile. | None                           |
| POST          | /api/profile/sync-zoho              | Create/update Contact and synchronise dependants.              | None                           |
| GET           | /api/profile/zoho-population-status | Diagnostic profile/Zoho population status.                     | None                           |
| GET/POST      | /api/intake/dependents              | Read Zoho dependants or save selected/excluded IDs.            | None                           |
| POST          | /api/intake/sync-dependent          | Create, update, or delete Partner_Dependents records.          | None                           |
| GET           | /api/questionnaires/count           | Count applications with meaningful questionnaire data.         | Firebase bearer                |

## Messaging

| Method | Route                           | Purpose                                                 | Auth                         |
|--------|---------------------------------|---------------------------------------------------------|------------------------------|
| GET    | /api/chat/messages              | Read up to 50 messages and clear reader unread flag.    | Firebase bearer + ownership  |
| POST   | /api/chat/send                  | Write message/conversation and update Zoho reference.   | Firebase bearer + ownership  |
| GET    | /api/chat/admin/conversations   | List latest 100 conversations; optional unread filter.  | Firebase bearer + admin role |
| GET    | /api/chat/widget/messages       | Read up to 100 messages by Zoho Deal ID.                | X-Admin-Key                  |
| POST   | /api/chat/widget/send           | Write CRM-widget admin reply and update Zoho reference. | X-Admin-Key                  |
| POST   | /api/messages/create            | Deprecated; returns HTTP 410.                           | None                         |
| GET    | /api/messages/fetch             | Deprecated; returns HTTP 410.                           | None                         |
| POST   | /api/messages/upload-attachment | Deprecated; returns HTTP 410.                           | None                         |

## Documents, corrections, resources, and review

| Method                 | Route                                        | Purpose                                                       | Auth                        |
|------------------------|----------------------------------------------|---------------------------------------------------------------|-----------------------------|
| GET                    | /api/uploads/matter-documents                | List/sort Deal-related Matter_Documents.                      | None                        |
| POST                   | /api/uploads/zoho                            | Validate and upload <=5 MB file to Zoho attachment.           | None                        |
| POST                   | /api/uploads/matter-documents/comment        | Update Matter_Documents Comments.                             | None                        |
| GET/<br>POST/<br>PATCH | /api/corrections                             | List, create, or edit Matter-linked Zoho Corrections.         | None                        |
| GET                    | /api/resources/shared                        | Return active shared resources for an authorised application. | Firebase bearer + ownership |
| GET                    | /api/resources/template                      | Return active visa-template notes and external links.         | Firebase bearer + ownership |
| GET                    | /api/review-pdf/application/{matterId}       | Find a Firestore application by Zoho Matter ID.               | None; Firestore rules apply |
| GET                    | /api/review-pdf/application/{matterId}/draft | Return questionnaire draft for public review.                 | None; Firestore rules apply |

## Diagnostics

| Method | Route                       | Purpose                                             | Auth |
|--------|-----------------------------|-----------------------------------------------------|------|
| GET    | /api/test/zoho-get          | Read a Zoho Contact for integration testing.        | None |
| POST   | /api/test/zoho-update       | Update a Zoho Contact for integration testing.      | None |
| GET    | /api/test/zoho-verify-token | Fetch token and verify Zoho Contacts module access. | None |

## 9. Where information is saved

| Information            | Primary location                                  | Details                                                                                |
|------------------------|---------------------------------------------------|----------------------------------------------------------------------------------------|
| User credentials       | Firebase Authentication                           | Passwords are managed by Firebase; the portal stores no plaintext password.            |
| Portal user profile    | Firestore users/{uid}                             | Personal/contact data, role, access flags, Zoho IDs, sync metadata, dependant summary. |
| Visa application shell | Firestore applications/{appld}                    | Owner, type/code, status, reference, timestamps, zohold, public review flag.           |
| Questionnaire answers  | Firestore applications/{appld}/data/questionnaire | Nested answers, profiles, per-profile sections, selected dependants, visa context.     |
| Completion/progress    | Firestore applications/{appld}/data/completion    | Page completion booleans and completionPercentage.                                     |
| Preferences            | Firestore users/{uid}/preferences/settings        | Current prefill setting.                                                               |
| Legacy current draft   | Firestore users/{uid}/drafts/current              | Only used by a real-time subscription path; application-scoped                         |

| Information                       | Primary location                                                   | Details                                                              |
|-----------------------------------|--------------------------------------------------------------------|----------------------------------------------------------------------|
|                                   |                                                                    | draft is primary.                                                    |
| Zoho contact snapshot             | Firestore users/{uid}/zoho/contact                                 | Server-synchronised Zoho data and timestamps.                        |
| Application messages              | Firestore conversations/{applicationId}/messages/{messageId}       | Message body, sender role/UID, and created time.                     |
| Conversation summary              | Firestore conversations/{applicationId}                            | Client/matter references, preview, latest time, and unread flags.    |
| Shared resources                  | Firestore resources/{resourceId}                                   | Active global notes and external links.                              |
| Visa resource templates           | Firestore resourceTemplates/{slug}/items/{itemId}                  | Active categorized notes and external links.                         |
| Dynamic questionnaire definitions | Firestore questionnaireDefinitions/{id}/pages/{pageId}             | Optional active override for code-defined pages.                     |
| Uploaded client files             | Zoho Matter_Documents/{id}/Attachments                             | PDF/JPG/PNG/DOC/DOCX/TXT, maximum 5 MB in the upload handler.        |
| Matter and CRM records            | Zoho Contacts/Deals/Partner_Dependents/Corrections/Client_Messages | CRM system-of-record entities and references.                        |
| Browser session                   | Firebase Auth IndexedDB persistence                                | Keeps the authenticated session across browser/tab closes.           |
| Fallback browser data             | localStorage adapter                                               | Used only when configured or when adapter initialisation falls back. |

## 9.1 Firestore path map

```

users/{uid}
├── profile and access metadata
├── preferences/settings
├── drafts/current                (legacy/current-draft listener)
└── zoho/contact                 (Zoho snapshot)

applications/{appId}
├── application metadata and zohoId
└── data/
    ├── questionnaire            (primary draft and applicant answers)
    ├── completion               (page flags and percentage)
    └── {dataType}               (adapter-supported application data)

conversations/{applicationId}
└── messages/{messageId}

resources/{resourceId}
resourceTemplates/{visaSlug}/items/{itemId}
questionnaireDefinitions/{definitionId}/pages/{pageId}

```

## 9.2 Browser localStorage fallback keys

```
ply_session
ply_user
ply_user_profile
intake_draft
intake_prefill
ply:applications
application-scoped draft, completion, and data keys generated by the adapter
ply-theme (ThemeProvider)
```

**Important:** Firebase Storage is not a document repository in this application. storage.rules denies all reads and writes. Changing upload storage requires a deliberate feature and security design, not only a Firebase configuration change.

## 10. Folder and code structure

```
validifypro-visa-portal/
├── app/                               Next.js App Router pages, layouts, and API handlers
│   ├── api/                          34 route-handler files
│   ├── applications/                 Application list and per-application workspace
│   ├── intake/                      110 visa-intake page files
│   │   ├── partner/                 43 pages
│   │   ├── protection/              29 pages
│   │   └── temporary-work/          38 pages shared by subclasses 186 and 482
│   ├── admin/                       Admin conversation pages
│   ├── profile/                     Profile and first-time setup
│   └── review-pdf/                   Matter-ID review and browser PDF surface
├── src/
│   └── components/                   Shared layout, navigation, form, intake, questionnaire, and UI
├── components
│   ├── hooks/                       Toast and draft-form hooks
│   └── lib/                          Firebase, Zoho, adapters, routes, validation, questionnaire
├── definitions
│   ├── stores/                      Valtio auth, applications, draft, and application-data state
│   ├── reuseable/                   Country/month option data and legacy reusable components
│   └── assets/                       Brand images
├── public/                           Fonts, logo, and login image
├── e2e/                              Playwright 186/482 questionnaire tests and harness
├── scripts/                          Seeding, backfill, and admin-page helpers
├── functions/                        Firebase Functions starter package; no active exported function
├── docs/                            Existing implementation notes and this generated guide
├── knowledgebase/                   Operational and testing notes
├── attached_assets/                 Screenshots and historical requirement material
├── firestore.json                   Firestore, Functions, and Storage configuration
├── firestore.rules                   Firestore client access rules
├── storage.rules                     Deny-all Firebase Storage rules
├── next.config.js                    Rewrites, headers, aliases, and Firebase env exposure
├── package.json                     Dependencies and scripts
└── .replit                          Node runtime, port 5000, and autoscale deployment
```

### 10.1 Key implementation files

| File/folder       | Responsibility                                                   |
|-------------------|------------------------------------------------------------------|
| app/layout.js     | Root metadata and provider shell.                                |
| app/providers.jsx | React Query, theme, AuthGuard, and navigation-loading providers. |

| File/folder                               | Responsibility                                                                     |
|-------------------------------------------|------------------------------------------------------------------------------------|
| <code>next.config.js</code>               | Visa-route rewrites, widget CORS headers, build aliases, and environment exposure. |
| <code>src/lib/firebase.js</code>          | Browser Firebase app, Auth, Firestore, and persistent login.                       |
| <code>src/lib/firebase-admin.js</code>    | Server Firebase Admin initialisation.                                              |
| <code>src/lib/serverAuth.js</code>        | Firebase token verification, role checks, and widget admin-key verification.       |
| <code>src/lib/zohoClient.js</code>        | Zoho token cache and CRM CRUD/related-record/attachment helpers.                   |
| <code>src/lib/adapters/firebase.js</code> | Current persistence adapter and application/draft/profile operations.              |
| <code>src/stores/draftStore.js</code>     | Questionnaire state, save/completion/import, applicant management, and CRM sync.   |
| <code>src/lib/routes.js</code>            | Visa-specific navigation, rewrites, and completion paths.                          |
| <code>src/lib/questionnaires/</code>      | Definition-based questionnaire loading, validation, and Firestore override.        |
| <code>app/api/</code>                     | Server routes integrating Firebase, Zoho, resources, messaging, and uploads.       |
| <code>firestore.rules</code>              | Owner-based client access and public-review exception.                             |
| <code>e2e/</code>                         | Playwright end-to-end questionnaire coverage.                                      |

## 10.2 Route aliases

| Public application route                               | Internal destination                                                           |
|--------------------------------------------------------|--------------------------------------------------------------------------------|
| <code>/applications/186/{appId}/intake/*</code>        | <code>/intake/temporary-work/*?applicationId={appId}&amp;__subclass=186</code> |
| <code>/applications/482/{appId}/intake/*</code>        | <code>/intake/temporary-work/*?applicationId={appId}&amp;__subclass=482</code> |
| <code>/applications/820/{appId}/intake/*</code>        | <code>/intake/partner/*?applicationId={appId}</code>                           |
| <code>/applications/866/{appId}/intake/*</code>        | <code>/intake/protection/*?applicationId={appId}</code>                        |
| <code>/applications/partner/{appId}/intake/*</code>    | <code>/intake/partner/*?applicationId={appId}</code>                           |
| <code>/applications/protection/{appId}/intake/*</code> | <code>/intake/protection/*?applicationId={appId}</code>                        |

## 11. Configuration and environment variables

| Variable                                         | Use                     | Notes                                                                                                                  |
|--------------------------------------------------|-------------------------|------------------------------------------------------------------------------------------------------------------------|
| <code>NEXT_PUBLIC_DATABASE_TYPE</code>           | Required                | Set to firebase in the current environment. Other accepted values: <code>localStorage</code> , <code>postgres</code> . |
| <code>NEXT_PUBLIC_FIREBASE_API_KEY</code>        | Required                | Firebase web configuration.                                                                                            |
| <code>NEXT_PUBLIC_FIREBASE_AUTH_DOMAIN</code>    | Required                | Firebase web configuration.                                                                                            |
| <code>NEXT_PUBLIC_FIREBASE_PROJECT_ID</code>     | Required                | Firebase web/Admin project and Firestore REST URL.                                                                     |
| <code>NEXT_PUBLIC_FIREBASE_STORAGE_BUCKET</code> | Required by initialiser | Configured even though Storage access is deny-all.                                                                     |

| Variable                                 | Use                        | Notes                                                                        |
|------------------------------------------|----------------------------|------------------------------------------------------------------------------|
| NEXT_PUBLIC_FIREBASE_MESSAGING_SENDER_ID | Required                   | Firebase web configuration.                                                  |
| NEXT_PUBLIC_FIREBASE_APP_ID              | Required                   | Firebase web configuration.                                                  |
| FIREBASE_SERVICE_ACCOUNT_KEY             | Required for server routes | JSON service account supplied as a secret; used by Firebase Admin.           |
| ACCESSTOKEN_URL                          | Zoho required              | Preferred Zoho access-token broker URL.                                      |
| ZOHO_ACCESS_TOKEN_URL                    | Zoho fallback              | Backward-compatible token broker variable.                                   |
| ZOHO_DATACENTER                          | Optional                   | Defaults to com.au.                                                          |
| PORTAL_ADMIN_KEY                         | Widget required            | X-Admin-Key expected from the Zoho CRM widget.                               |
| ZOHO_WEBHOOK_SECRET                      | Production required        | Bearer secret for user provisioning, revocation, and contact-update webhook. |
| PORTAL_RESET_EMAIL_WEBHOOK_URL           | Password reset             | Webhook that sends the generated reset link.                                 |
| NEXT_PUBLIC_APP_URL / APP_URL            | Optional                   | Base URL used to build password-reset links; localhost fallback exists.      |
| NEXT_PUBLIC_BASE_URL                     | Optional                   | Base URL included in Zoho admin chat links.                                  |
| DATABASE_URL                             | Inactive adapter           | Required only by Drizzle tooling; Postgres adapter is not implemented.       |
| NEXT_DIST_DIR                            | Optional                   | Overrides the Next.js build directory.                                       |
| E2E_PORT / CI                            | Test only                  | Playwright port and CI behaviour.                                            |

## 11.1 Configuration files

| File                   | Purpose                                                                                                  |
|------------------------|----------------------------------------------------------------------------------------------------------|
| next.config.js         | App rewrites, widget CORS headers, aliases, body-size limit, and public Firebase variables.              |
| firebase.json          | Default Firestore database in asia-east2, Storage rules, and functions codebase.                         |
| firestore.rules        | Owner access, active-resource reads, admin definition/template writes, and explicit public-review reads. |
| storage.rules          | Deny all.                                                                                                |
| tailwind.config.js/.ts | Theme, fonts, colours, and component scanning.                                                           |
| playwright.config.js   | E2E server and browser configuration.                                                                    |
| drizzle.config.ts      | Dormant PostgreSQL migration configuration.                                                              |
| .replit                | Node 20 module, dev/start commands, port 5000, and autoscale deployment.                                 |

## 12. Local development, build, and deployment

### 12.1 Prerequisites

- Node.js 20 or newer for the Next.js application; Node.js 22 for Firebase Functions if that package is deployed.
- pnpm is preferred because pnpm-lock.yaml is committed.
- A Firebase project with Email/Password authentication enabled, Firestore created, and the documented environment variables.
- A Zoho token-broker endpoint and CRM modules/fields matching the integration.

### 12.2 Common commands

```
pnpm install
pnpm dev           # Next.js dev server on port 5000
pnpm build         # production webpack build
pnpm start         # production server on port 5000
pnpm check         # TypeScript no-emit check
pnpm test:e2e      # Playwright tests
pnpm questionnaires:seed # seed active questionnaire definitions into Firestore
pnpm db:push       # Drizzle push; only relevant if Postgres work is completed
```

### 12.3 Deployment

The committed .replit file configures an autoscale deployment that runs npm run build and npm run start, with application port 5000 exposed externally. A Netlify Next.js plugin is installed as a development dependency, but no Netlify configuration was found. Firebase Hosting is not configured.

**Firebase Functions:** The functions package targets Node.js 22 and caps each function at 10 instances, but functions/index.js currently exports no deployed business handler.

## 13. Testing and verification

| Test                                                     | Coverage                                           |
|----------------------------------------------------------|----------------------------------------------------|
| e2e/questionnaire-186.spec.js                            | End-to-end Employer Nomination questionnaire flow. |
| e2e/questionnaire-482.spec.js                            | End-to-end Skills in Demand questionnaire flow.    |
| e2e/support/questionnaireHarness.js                      | Shared Playwright setup and questionnaire helpers. |
| src/lib/adapters/__tests__/factory.test.js               | Adapter selection.                                 |
| src/lib/adapters/__tests__/localStorage.test.js          | Browser fallback persistence.                      |
| src/lib/questionnaires/__tests__/validation.node.test.js | Questionnaire-definition validation.               |
| src/stores/__tests__/draftStore.nonMigrating.test.js     | Non-migrating member draft behaviour.              |

Only Playwright and the TypeScript checker have package scripts. The small Node tests need an explicit runner/command if they are to be part of CI. Current E2E coverage is strongest for subclasses 186 and 482; partner, protection, messaging, uploads, webhooks, and access control need dedicated automated coverage.

## 14. Security and operational notes

**Immediate action:** The repository currently tracks `.env` and two Firebase service-account JSON files even though `.gitignore` now excludes `.env`. Treat the credentials as exposed: rotate them, remove the files from Git history, and move all secrets to the deployment secret store.

| Severity | Area                     | Current observation                                                                                                                                      | Recommended action                                                       |
|----------|--------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------|
| Critical | Tracked secrets          | <code>.env</code> , <code>firebase-service-account.json</code> , and <code>validate-pro-test-firebase-adminsdk-fbsvc-4f4b7a7e17.json</code> are tracked. | Rotate credentials and purge Git history.                                |
| High     | Missing route-level auth | Several profile, dependant, deal, correction, upload, review, and test routes do not verify caller identity/ownership.                                   | Add central auth/authorisation; disable diagnostic routes in production. |
| High     | Webhook fail-open        | Webhook/admin routes enforce <code>ZOHO_WEBHOOK_SECRET</code> only when the variable is configured.                                                      | Fail closed when the secret is absent.                                   |
| High     | Credential logging       | <code>firebase-admin.js</code> logs the length and first 50 characters of <code>FIREBASE_SERVICE_ACCOUNT_KEY</code> .                                    | Remove all credential-derived logs.                                      |
| High     | Upload route             | <code>/api/uploads/zoho</code> validates file type/size but does not authenticate or verify Deal ownership.                                              | Require Firebase token and application ownership.                        |
| Medium   | Public review            | Matter-ID review routes have no route auth; Firestore <code>publicReviewAccess</code> is the effective gate.                                             | Keep the flag false by default and add signed/time-limited access.       |
| Medium   | Debug ingestion          | <code>draftStore</code> and one partner page call a hard-coded <code>127.0.0.1:7242</code> ingest endpoint.                                              | Remove debug calls before release.                                       |
| Medium   | CORS scope               | Zoho widget routes return <code>Access-Control-Allow-Origin: *</code> .                                                                                  | Restrict allowed origins if the widget host is stable.                   |
| Medium   | Reset token lifetime     | The Zoho reset-token hash has no expiry timestamp in the current flow.                                                                                   | Store and enforce an expiry and single-use audit data.                   |
| Low      | Dormant code             | Postgres, Express/Vite remnants, deprecated routes, backups, and test pages expand the maintenance surface.                                              | Remove once confirmed unused.                                            |

### 14.1 Existing safeguards

- Firestore owner rules protect users and application subcollections; unrecognised paths are denied.
- Authenticated chat routes verify Firebase ID tokens and application ownership; admin conversation listing checks the admin role.
- Zoho widget routes require `PORTAL_ADMIN_KEY`.
- Login fails closed if Zoho eligibility cannot be verified.

- Password-reset responses avoid disclosing whether an email exists.
- Uploads enforce a 5 MB size limit and an allow-list of document MIME types.
- Firebase Storage denies all reads and writes.

## 15. Maintenance guide and appendices

### 15.1 Where to make common changes

| Task                             | Primary locations                                                                        |
|----------------------------------|------------------------------------------------------------------------------------------|
| Add/edit a static intake page    | app/intake/{flow}/.../page.js plus src/lib/routes.js.                                    |
| Change questionnaire route order | src/lib/routes.js and completion/validation helpers.                                     |
| Add a definition-driven question | src/lib/questionnaires, questionnaire renderer components, then run questionnaires:seed. |
| Change data persistence          | src/lib/adapters/firebase.js; keep Firestore rules and server routes aligned.            |
| Change profile/CRM mapping       | src/lib/zohoClient.js and app/api/profile routes.                                        |
| Change Deal/application mapping  | app/api/applications/fetch-zoho-deals/route.js and src/lib/visaDisplay.js.               |
| Change document uploads          | application uploads page, /api/uploads routes, and Zoho Matter_Documents fields.         |
| Change messaging                 | application/admin message pages, /api/chat routes, and Zoho Client_Messages fields.      |
| Change resources                 | /api/resources routes, Firestore resource collections, and resource page.                |
| Change access control            | src/lib/serverAuth.js, each route handler, firestore.rules, and AuthGuard.               |
| Change deployment                | .replit, package scripts, runtime secrets, and Firebase/Zoho configuration.              |

### 15.2 Route surface summary

| Surface                     | Count         | Notes                                                                                               |
|-----------------------------|---------------|-----------------------------------------------------------------------------------------------------|
| Top-level page routes       | 131           | Authentication, profile, application workspace, intake, admin, and review.                          |
| Intake pages                | 110           | Partner 43; protection 29; temporary-work 38.                                                       |
| API route files             | 34            | Auth/admin, applications, profile, intake, chat, resources, uploads, review, and tests.             |
| Application workspace pages | 9 child pages | Questionnaire, uploads, resources, corrections, messages, tasks, review, deliverables, plus layout. |
| Admin pages                 | 2             | Conversation list and detail.                                                                       |
| Public review pages         | 1             | Matter-ID questionnaire review and print.                                                           |

### 15.3 Repository snapshot notes

- Documented commit: 86740ed, dated 2026-06-28.
- The working tree was inspected without reading or reproducing secret values.
- Historical markdown plans and attached screenshots remain useful background, but the code and active configuration were treated as authoritative.
- The product metadata names the application “Ply Legal | Client Portal”; the repository/workspace name remains validifypro-visa-portal.

**End of guide:** Update this document after material changes to authentication, persistence, Zoho modules, route access control, supported visa flows, or deployment.